

VIETNAM NATIONAL UNIVERSITY
HO CHI MINH CITY
UNIVERSITY OF INFORMATION
TECHNOLOGY

SOCIALIST REPUBLIC OF VIETNAM
Independence – Freedom – Happiness

Ho Chi Minh City, July 17, 2019

**REGULATION
ON INFORMATION SECURITY ASSURANCE**

(Issued together with Decision No. 408/QĐ-ĐHCNTT dated July 17, 2019,
by the President of the University of Information Technology)

**CHAPTER I
GENERAL PROVISIONS**

Article 1. Scope of Regulation and Subjects of Application

1. This Regulation stipulates the scope of information resources as well as the fundamental principles, policies, and measures to ensure information security in the information technology application activities of the VNUHCM-University of Information Technology (hereinafter referred to as UIT).
2. This Regulation applies to all subordinate units of UIT (hereinafter referred to as "units") and individuals, including staff, civil servants, public employees, lecturers, researchers, employees within the units, undergraduate, and graduate students (hereinafter collectively referred to as "individuals") involved in the university's information technology application activities.

Article 2. Interpretation of Terms

For the purposes of this Regulation, the following terms shall be understood as defined below:

1. *Information Security Assurance* means the protection of information and information systems against unauthorized access, use, disclosure, disruption, modification, or destruction to ensure the integrity, confidentiality, and availability of information.
2. *Information Security Breach* means acts of unauthorized access, use, disclosure, disruption, modification, or destruction of information and information systems.
3. *Technical Infrastructure* means the set of computing devices, storage devices, peripheral devices, networking devices, auxiliary equipment, transmission lines, local area networks (LAN), and wide area networks (WAN).
4. *Information System* means a database and a set of hardware and software established for the purpose of creating, providing, transmitting, collecting, processing, storing, and exchanging information over a network environment.

5. *Website* means a single page or a collection of web pages on a network used to provide and exchange information.
6. *Electronic Information Portal* means the sole access point of an organization or unit on the network that integrates various information channels, services, and applications, through which users can access, utilize, and personalize information display.
7. *Malware* means software that can cause abnormal operations in part or all of an information system or illegally copy, modify, or delete stored information.
8. *Communication Port* is used to identify applications that send and receive data. Each application is (non-exclusively) associated with a specific port number. Common applications are assigned predefined port numbers for unique identification. When a computer uses a service, the corresponding communication port for that service will be opened.
9. *System Log File* means a file generated on each device within the information system (e.g., security devices, computing devices, application servers, etc.) that records all activities occurring on that device. The log file is used to analyze past events, their origins, and consequences, thereby supporting appropriate remedial actions.
10. *Mobile Storage Devices* means devices used to read/write data that can be moved between locations and shared by multiple users (e.g., portable hard drives, USB drives, laptops, memory cards, CDs, DVDs, etc.).
11. *Online Storage* means a method of data storage that utilizes the storage applications of service providers. Data is uploaded to the servers of the storage service providers.
12. *User* means an individual who uses a computer or mobile device with access to the university's network and information systems.
13. *Standard TCVN 7562:2005* means Vietnam's standard on information security management practices (equivalent to ISO/IEC 17799:2000).

Article 3. Information Resources Requiring Security Assurance

The following components are considered information resources that require information security assurance:

1. Technical Infrastructure:
 - a) Internet connectivity network of UIT, local area network (LAN), networking devices, security devices, and auxiliary equipment.
 - b) Computing and storage devices (servers, workstations, SAN, NAS, etc.).
 - c) Peripheral devices (printers, scanners, digital devices, mobile storage devices, etc.).
 - d) Information technology devices connected to the network within units.
2. Software, Applications, and Databases:
 - a) Websites/portals of UIT and its affiliated units and organizations.

- b) Software and applications supporting UIT's management and operational activities and its affiliated units and organizations.
 - c) Software and applications that provide online services.
 - d) Network services.
 - e) Shared databases.
3. Information and Data that are exchanged, transmitted, processed, and stored on UIT's technical infrastructure.

Article 4. General Principles of Information Security Assurance

1. Ensuring information security is a mandatory requirement that must be consistently and continuously maintained throughout the following processes:
 - a) Collecting, generating, processing, transmitting, storing, and using information and data.
 - b) Designing, building, operating, upgrading, improving, and decommissioning information systems.
2. Units and individuals are responsible for fully and strictly complying with the laws and UIT's internal Regulation on information security assurance.
3. Information technology application projects, or projects with IT components, must undergo an assessment of information security-related content before being approved.
4. When leasing or using information technology services provided by third parties, units and individuals must manage the ownership of information and data obtained through those services; require service providers to ensure information confidentiality; ensure that service providers do not access or use information or data without the explicit authorization of the respective individual or unit.
5. The handling of information security incidents must comply with relevant responsibilities and authority, ensure the legitimate rights and interests of concerned units and individuals, and conform to applicable legal provisions.

Article 5. Prohibited Acts

1. Violating regulations and procedures related to the management, operation, use, and assurance of information security for UIT's information systems.
2. Unauthorized access or interference that alters, compromises, or damages information or data, or infringes upon the information security of other agencies, units, or individuals.
3. Attacking or interfering with the normal operation of information systems, or unlawfully obstructing or disrupting users' legitimate access to such systems.
4. Using UIT's information resources to distribute spam emails, spam messages, malicious software, or to establish fraudulent or deceptive information systems.

CHAPTER II

INFORMATION SECURITY ASSURANCE ACTIVITIES

Article 6. Physical-Level Information Security Assurance

1. Physical-level information security assurance involves protecting technical infrastructure, software, applications, and databases from physical threats (such as fire, explosion, temperature and humidity outside allowable ranges, natural disasters, power outages, mechanical impact) that may affect system operations.
2. Basic measures to ensure physical-level information security include:
 - a) Data center/server room management:
 - Critical networking and security devices such as firewalls, routers, servers, SAN and NAS storage systems must be placed in the data center/server room.
 - The data center/server room must have appropriate protection mechanisms, monitoring systems, intrusion detection, and physical access control measures for each specific area, including: servers and storage systems; network and patch panels; power supplies and backup power systems; system operation, monitoring, and administration.
 - Entry and exit activities in the data center/server room must be logged in a designated logbook. Only authorized individuals assigned by the head of the unit are permitted to enter the data center/server room. Advanced authentication mechanisms (cards, tokens, fingerprints, etc.) must be implemented when necessary.
 - There must be contingency plans for incidents such as water leakage, lightning, static electricity, fire, and explosion. Technical standards on temperature, humidity, and lighting safety for computing and storage devices must be applied to ensure stable operating conditions for support systems such as air conditioners, power supply units, and cabling systems.
 - The data center/server room must be equipped with an uninterruptible power supply (UPS) system with sufficient capacity to maintain the operation of servers for at least 10 minutes in the event of a power outage.
 - b) Establishing backup mechanisms for critical technical infrastructure devices; implementing regular inspection and maintenance plans to preserve the devices' technical specifications or ensure timely repair/replacement in line with availability requirements during their deployment and usage.
 - c) Data transmission lines, internet connections, and cabling systems for WAN and LAN networks must be installed in closed conduits or protective trays to restrict unauthorized access. Unused Ethernet ports, especially those in shared working areas, must be disconnected.

- d) Individuals using mobile data storage devices to store their unit's information and data are responsible for protecting both the devices and the data contained therein. Loss or leakage of information must be prevented. It is prohibited to bring overseas any unit- or state-related information or data that is not directly associated with assigned duties abroad.
 - e) Computing devices with internal storage components or removable storage devices containing sensitive data must have those components removed or data wiped before being sent out for warranty service, maintenance, or repair (except when required for data recovery). When decommissioning devices, data must be permanently erased using dedicated software, hardware data destruction tools, or by physical destruction of the storage medium.
3. Each unit is responsible for establishing procedures for the maintenance and operation of its technical infrastructure; providing user guidance and management instructions; and appointing a specialized IT department to oversee operations, conduct regular inspections, repairs, and maintenance of devices (both active and backup devices).

Article 7. Ensuring Information Security When Using Computers

1. Individuals using computers for work purposes must comply with the following regulations:
- a) Only install legitimate software (commercially licensed software, internally developed software, or open-source software with clearly identifiable origins); users are not permitted to install or uninstall software without prior approval from the designated IT department; software and operating systems must be regularly updated.
 - b) Install anti-malware software and configure it to automatically update its database; perform scans for malicious software when copying, opening files, or before connecting mobile storage devices to the computer.
 - c) If any signs of malware infection are detected (such as unusual system slowdown, warnings from security software, data loss, etc.), the computer must be shut down immediately, and the designated IT department must be notified for prompt handling.
 - d) Only access trusted websites, portals, and online applications, and only those related to one's job functions, responsibilities, and authority; use secure web browsers; do not visit or open websites or emails from unknown sources; avoid using features that automatically save passwords or enable auto-login.
 - e) Users are responsible for keeping access account information confidential and must not share passwords or personal information with others. Passwords must meet strong security requirements (including lowercase letters, uppercase letters, numbers, and special characters such as @, #, !, etc.) and should be changed at

least once every three months. All system access accounts must be logged out when not in use; users should regularly clear saved forms, passwords, cache, and cookies from their browser.

- f) Lock the computer (using the system's built-in function) when stepping away from the workstation; shut down the computer when leaving the office.
- 2. Units are responsible for compiling and updating guidance documents and regulations related to ensuring information security when using computers (tailored to the operational environment and technological developments), and for disseminating these materials to all individuals within their unit to ensure compliance.
- 3. User Accounts:
 - a) Individuals using information systems shall be issued and use access accounts with unique identifiers linked to themselves. Shared information systems of UIT shall employ a single sign-on mechanism using one shared username and password.
 - b) In the event of a job transfer, reassignment, resignation, retirement, or termination of studies (for students and graduate learners), the managing unit must, within no more than 05 working days, notify the system administrator to adjust, revoke, or cancel access rights to the information systems. Email accounts shall be retained for one month; special cases are subject to the decision of the President.
 - c) System administrator accounts (for networks, operating systems, networking devices, software, applications, databases) must be separated from regular user access accounts. Each system administrator account must be assigned to a specific individual responsible for administration. Shared use of system administrator accounts should be limited.

Article 8. Ensuring Information Security in Computer Networks

- 1. The internal network system (LAN) must be segmented based on fundamental functions (in accordance with specific information security policies), including: Network segment connecting to UIT's wide area network (WAN); User network segment; Network segment for external Internet and third-party connections; Public server network segment; Internal server network segment; Administrative server network segment. Data exchanges between network segments must be monitored and managed through network and security devices.
- Depending on actual conditions and data security requirements, agencies or units managing the internal network system are responsible for proactively implementing network models and security solutions, including the following technical measures:
- a) Controlling external access to the network (using secure communication protocols that support encryption, such as SSH, SSL/TLS, VPN, or equivalent.)

- b) Controlling internal access (by managing end-user devices connected to the network; monitoring and blocking internal attempts to access blacklisted Internet addresses).
 - c) Preventing intrusions and malware; protecting public server zones, internal servers, databases, and internal network zones; supporting real-time automatic updates of attack detection databases; disabling all unnecessary services within each network segment.
 - d) Configuring authentication functions on network devices to verify the identity of administrators accessing the devices either locally or remotely.
 - e) Wireless networks must ensure the integrity and confidentiality of transmitted data. Guidelines must be provided to ensure secure use of end-user devices. Wireless networks should be configured with parameters including network name (SSID), password, access control based on MAC address, and encryption protocols. Passwords must be updated regularly. Wireless access points must be secured against unauthorized access.
 - f) Server systems must automatically update system log files at specific intervals (at least every 3 months), storing information such as network connections, login sessions, configuration changes, system errors, and other relevant security information to support incident response and investigation. All data must be thoroughly deleted from servers before transfer or repurposing.
2. Units connecting to or using the university-wide WAN are responsible for:
- a) Ensuring the security of their internal networks and devices when connected to the WAN; promptly reporting incidents or malicious activities to UIT's IT operations unit for coordinated resolution.
 - b) Coordinating with UIT's IT operations unit to review and validate WAN IP configurations during the use of information systems, servers, and IT equipment connected to the WAN.
 - c) Periodically backing up shared data stored on the WAN.
 - d) Not disclosing access credentials (usernames, passwords, utilities, support files, and other access methods) to third parties; not attempting to access restricted areas of the WAN in any form.
3. Units must implement necessary technical measures to ensure information security when connecting to the Internet, meeting at least the following requirements:
- a) Employ firewall systems and Internet access control systems capable of handling concurrent connections, supporting common virtual private network (VPN) technologies, and incorporating hardware-based encryption acceleration. These systems must offer essential security features such as NAT, PAT, inbound/outbound traffic management, and protection against denial-of-service (DoS/DDoS) attacks.

3317
CỘNG
HÒA
XÃ HỘI
VIỆT
NAM
Độc lập
Tự do
Hòa bình
Thống nhất

- b) Filter and block access to websites suspected of containing malware or inappropriate content.
- c) Do not access websites or online applications from computers that store or have access to sensitive data. Internet access should be enabled only on servers and IT equipment that require Internet connectivity (e.g., servers for public websites, e-government services, email, software/license/OS updates, malware signature databases, vulnerability scans, and attack detection models).

Article 9. Ensuring Information Security at the Software and Application Level

1. Units responsible for the development, operation, and use of software and applications must meet the following requirements:
 - a) Information security requirements must be incorporated into all stages of design, development, deployment, operation, and use of software and applications.
 - b) Configure software and applications to authenticate users; limit the number of consecutive failed login attempts; set session timeout intervals; encrypt authentication information within the system; discourage the use of automatic login features.
 - c) Define access permissions, administrative rights, and usage levels for different users/user groups based on their respective roles and responsibilities; separate the management interface from the service delivery interface; disable unused communication ports.
 - d) Only allow remote access and management of software and applications via network protocols that support encryption such as SSH, SSL/TLS, VPN, or equivalent; restrict access to source code, which must be stored in a secure environment managed by the designated IT department.
 - e) Record and retain system log files of software and applications for a minimum of 3 months, including basic information such as: timestamp, address, account (if applicable), details of access and usage, errors occurring during operation, and login information for administrative access.
 - f) Implement a control process for the installation, update, and patching of security vulnerabilities in software and applications on servers, personal computers, and network-connected devices operating within the internal network.
 - g) Perform vulnerability assessments and remediation before deployment and during operation of applications (particularly when new vulnerabilities are discovered in the application's operating environment. This should be conducted at least once a year).
2. The unit responsible for operating UIT's information systems shall coordinate with the departments managing shared systems and databases of UIT to:

- a) Develop and agree upon plans and solutions to ensure the information security of software systems.
- b) Regularly monitor and supervise information security and inspect software operations.
- c) Develop backup plans and incident response and recovery strategies.

Article 10. Ensuring Information Security at the Data Level

1. Units assigned with the responsibility of protecting information and data related to official duties, sensitive or critical content, or non-public information must:
 - a) Establish measures to ensure the confidentiality, integrity, and availability of information and data; monitor and issue alerts when changes occur or when unauthorized access, sending, or receiving of data is detected or attempted. The use of digital signatures for authentication and data security is encouraged, particularly in cases where non-repudiation of data origin is required.
 - b) Encrypt information and data stored on storage systems/devices using solutions approved by UIT's specialized IT department. Encrypted storage partitions must be configured, allowing access and storage only by authorized individuals with appropriate responsibilities.
 - c) Implement independent storage systems/devices, separate from service server storage, for backup purposes. Classify and manage stored information and data according to predefined labels or categories. Regularly back up the following essential information and data: system configuration files, server operating system images, databases, and business-related data.
2. Units must regularly inspect and monitor the sharing, sending, and receiving of information and data in internal activities. It is recommended that information shared or transmitted over the network be protected by passwords.
3. In cases of external information and data exchange, units and individuals must commit to and implement data protection measures. External parties must meet agreed-upon standards for connectivity and information protection, in compliance with UIT's information security regulations. Implement mechanisms to detect malicious software in attached data, ensure secure wireless communications, and encrypt information and data prior to transmission or exchange over the network in accordance with legal regulations.
4. Online transactions must be fully transmitted to the correct address, and be protected against unauthorized modification, disclosure, or duplication. Strong authentication mechanisms and digital signatures must be used, along with secure communication protocols.

Article 11. Ensuring Information Security during the Acquisition, Development, Operation, and Maintenance of Information Systems

1. When acquiring, developing, upgrading, or maintaining an information system, units must analyze and identify potential risks, assess their impact scope, and prepare mitigation or elimination measures. All related providers, contractors, and individuals must comply with these measures.

Key requirements include:

- a) An information security plan must be reviewed and approved by the IT-specialized department/unit during the development, expansion, or upgrade of the information system.
 - b) Information systems may only be accepted and put into operation after acceptance testing and verification have been performed (approved by the IT-specialized unit and the system owner).
 - c) Information systems must be accompanied by:
 - Documentation describing the scale, scope, and target users, exploitation, and system management;
 - Documentation describing all system components, including network zones, network and security equipment, system and application servers, services, and other relevant components.
 - d) Compatibility with existing software and applications must be considered to ensure stable and secure operations before deciding to upgrade to a newer operating system version. Software or application expansion/upgrades must be tightly controlled. Any additional devices introduced into the system must follow planned procedures that ensure no disruption to ongoing operations.
 - e) System maintenance must be planned in advance and carried out regularly.
2. During system operation, the managing unit must:
 - a) Assess and categorize the information system according to its level, and implement security measures that meet the basic requirements in relevant standards and regulations on graded information system protection.
 - b) Regularly monitor compliance with information security regulations, fully update security vulnerabilities, apply backup mechanisms, and ensure secure access and login.
 - c) Monitor system security, detect violations or potential security incidents, analyze critical factors affecting system safety, and propose changes in technical measures.
 - d) Monitor system performance and implement necessary maintenance actions (e.g., system cleanup, parameter tuning, procurement) to ensure processing capacity and system availability.

- e) Follow established operational and incident handling procedures. Ensure full logging of system activities, and maintain these logs for a defined period to support information management and control.
- 3. Software/application development partners are responsible for ensuring information security during development, operation, warranty, and maintenance, preventing source code, data, and system design/management documents from being leaked or exposed.
- 4. Technical measures to ensure information security for web portals and websites include:
 - a) Defining the architecture and design of the website/portal: manage all versions of source code; applications of the website/portal; collaborate with server administrators to organize the system architecture to prevent privilege escalation attacks; ensure hosting service providers implement defenses such as firewalls, intrusion detection/prevention systems (IDS/IPS), and Web Application Firewalls (WAF).
 - b) Operating software, websites/portals applications: before deployment or when adding new online public services, security assessments must be conducted to prevent common web application vulnerabilities (e.g., SQL Injection, Cross-Site Scripting, Broken Authentication and Session Management, Insecure Direct Object References, Cross Site Request Forgery, Security Misconfiguration, Failure to Restrict URL Access, Insecure Cryptographic Storage, Insufficient Transport Layer Protection, Unvalidated Redirects and Forwards, etc.).
 - c) Configuring website/portal databases:
 - Always apply the latest security patches to database management systems; use tools to identify vulnerabilities on database servers;
 - Remove unused databases;
 - Establish automatic daily backup mechanisms, preferably to devices or servers separate from the database server.
 - d) In collaboration with server administrators, develop a recovery plan for the website/portal, including at least a monthly full backup, including source code, databases, unstructured data, to ensure minimal downtime in the event of an incident.

Article 12. Inspection and Incident Response for Information Security

1. The information system management unit is responsible for coordinating with the specialized units in information technology and cybersecurity at UIT to:

- a) Review, assess, and identify information security incidents and potential risks for each component of the information system under its management. Based on this, develop and approve appropriate incident response and remediation plans;
 - b) Prepare technical measures and tools to implement the established response plans;
 - c) Develop and issue incident response procedures and guidelines tailored for specific user groups within the information system;
 - d) Publicly communicate the contact methods with the incident response team and response procedures to all individuals related to the managed information system;
 - e) Regularly verify the readiness of incident response plans and ensure strict adherence to the established response procedures and guidelines.
2. In the event of a security incident or a threat to information safety, the head of the unit shall:
- a) Direct the investigation of the root cause of the incident and promptly implement corrective measures to minimize damage;
 - b) For high-severity or emergency incidents (such as: service interruption; possible disclosure of top secret or state-confidential data; critical data integrity issues with no possibility of recovery; loss of control over the system) or where the system owner lacks sufficient capability to respond, the unit must coordinate closely with the specialized IT and security units of UIT and provide complete incident information to receive proper guidance and support;
 - c) Prepare a detailed incident report, including the following:
 - Name and address of the unit operating the affected information system, the system owner, and the impacted system; time the incident was detected;
 - Contact point for the incident at the operating unit: name, position, phone number, email;
 - Description of the incident: type, symptoms, preliminary assessment of the severity, propagation level, and impact on the organization's normal operations;
 - Information on infrastructure service providers involved;
 - List of implemented or planned remediation measures;
 - Organizations or companies involved in response efforts and current resolution status;
 - Initial results of the incident response;
 - Suggestions or recommendations for further incident handling (if any);
 - The latest version of the documentation describing the system components, including: network zones, network devices, security equipment, system servers, application servers, services, and other relevant system components (in cases where the incident may have widespread or cascading effects on critical systems).
3. The head of the unit owning the information system shall lead and coordinate with UIT's specialized IT and security units to continuously monitor the evolution of the

incident (especially at high or emergency levels), notify and update relevant stakeholders, analyze the incident, implement remedial actions, and remove any malicious software.

CHAPTER III IMPLEMENTATION

Article 14. Responsibilities of Units

1. Direct and ensure compliance with the provisions of this Regulation within their organizational scope and authority, and report on the implementation as requested by the specialized IT unit of UIT.
2. Based on this Regulation and the unit's actual needs, develop or review and amend the currently applied information security management plans accordingly.
3. Disseminate and propagate the contents of this Regulation to each individual within the unit; raise awareness about information security risks among individuals.
4. Coordinate, provide information, and facilitate the specialized IT units, system operation, and information security units of UIT to promptly, quickly, and effectively carry out inspection and incident response activities.

Article 15. Responsibilities of Individuals

1. Individuals responsible for information security shall:
 - a) Advise the unit head to issue internal regulations and procedures, and be responsible for implementing technical solutions to ensure information security at the unit in accordance with this Regulation.
 - b) Monitor, evaluate, and report to the unit head on information security risks and their severity.
 - c) Coordinate with relevant individuals and units to inspect, detect, and remedy information security incidents.
2. Users shall:
 - a) Strictly comply with the unit's information security regulations, this Regulation, and other applicable laws; raise vigilance and responsibility for ensuring information security within their assigned scope and authority.
 - b) Manage and safeguard the equipment assigned for their use. Upon detecting any incident, immediately report to superiors and the specialized IT unit for timely prevention and handling.
 - c) Actively participate in training programs and conferences on information security organized by professional units.

Article 16. Responsibilities of the IT & Data Resource Management Office

1. The IT & Data Resource Management Office serves as the specialized IT unit and information system operation unit of UIT, assisting the President in managing information security in the IT application activities at UIT as prescribed by this Regulation and related laws.

2. The IT & Data Resource Management Office is responsible for:
 - a) Advising the President on developing, revising, and supplementing information security policies and regulations at UIT.
 - b) Leading and coordinating with related units to disseminate, guide implementation, inspect, evaluate, and monitor compliance with this Regulation within UIT; regularly report to the President on implementation status; conduct communication to raise awareness linking information security assurance with IT application.
 - c) Determining the security level of UIT's and units' information systems.
 - d) Implementing measures to ensure information security for UIT's technical infrastructure, software, applications, and databases.
 - e) Periodically evaluating the effectiveness of information security measures implemented at UIT and reporting to the President for adjustments if necessary.
 - f) Periodically or unexpectedly reporting on information security enforcement at UIT as requested by the President or competent state authorities.
 - g) Coordinating and complying with requests from relevant state authorities in information security assurance.
 - h) Other tasks as required by the President.
3. The IT & Data Resource Management Office is responsible for preparing plans and budget estimates to perform the duties specified in Clause 2 of this Article for the President's approval according to regulations.

Article 18. Rewards and Handling of Violations

1. Units and individuals violating this Regulation shall, depending on the nature and severity of the violation, be subject to administrative sanctions, disciplinary actions, or other handling forms according to current regulations; if the violation causes significant damage to UIT's information resources, they must be held liable for the damages in accordance with the law.
2. Complaint, denunciation, and dispute resolution shall be conducted in accordance with relevant legal provisions.

Article 19. Implementation Clause

During the implementation of this Regulation, if there are any difficulties or issues, units and individuals shall report to the IT & Data Resource Management Office for consolidation and submission to the President of UIT for consideration and appropriate amendment or supplementation of the Regulation.

PRESIDENT

Nguyen Hoang Tu Anh